API Behaviour & Specification Discrepancy Report

During the development of this automation framework against the automationintesting.online Booking API, significant drift was discovered between the provided OpenAPI/YAML specification and the live API's behaviour.

Because API documentation frequently falls behind live system updates (often due to security patches or agile iterations), this framework was deliberately architected to assert the **actual live behaviour** of the API to ensure pipeline stability, while explicitly logging contract deviations as Allure step findings.

Below is the summary of the discrepancies and stability issues uncovered.

1. Specification Discrepancies (Documentation Drift)

These findings indicate areas where the YAML contract is likely outdated compared to the live system's current implementation.

- **Response Structure Flattening (POST /booking)**
  - **Documented Spec:** The YAML indicates the POST response should return a nested object (a booking wrapper containing the details, alongside a bookingid).
  - **Live API Behaviour:** The API returns a flat JSON object where the bookingid and booking details exist at the same root level.
  - **Analysis:** The framework was adapted to parse the flat object to ensure test stability.
- **PII Data Stripping (Missing Email/Phone)**
  - **Documented Spec:** The schema states email and phone are required fields in the booking response payload.
  - **Live API Behaviour:** The API intentionally strips email and phone from the responses of POST /booking, GET /booking/{id}, and PUT /booking/{id}.
  - **Analysis:** This is highly likely a deliberate security update to protect Personally Identifiable Information (PII) that was never updated in the YAML. The framework explicitly logs this omission without failing the tests.
- **Status Code Discrepancies**
  - **Documented Spec:** The YAML states POST returns 200 OK and DELETE returns 201 Created.
  - **Live API Behaviour:** The API correctly aligns with standard REST semantics, returning 201 Created for POST and 200 OK for DELETE.
- **Boundary Value Mismatch (firstname & lastname)**
  - **Documented Spec:** The schema defines a strict maximum length of 18 characters for both firstname and lastname.

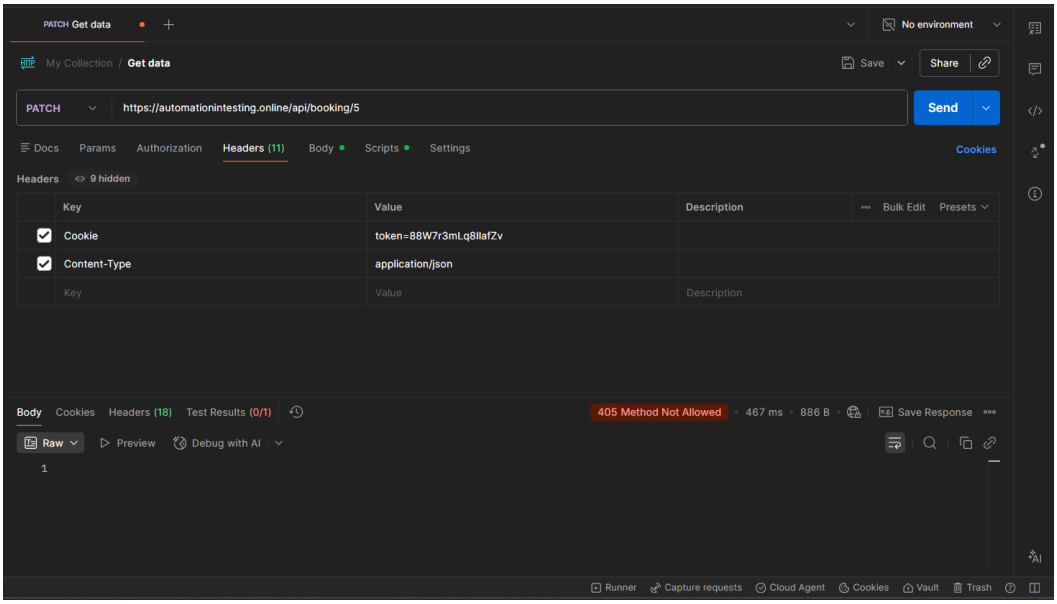
    - **Live API Behaviour:** The validation layer is significantly looser, accepting strings up to 30 characters (rejecting at 31 with a "size must be between 3 and 30" validation error).
    - **Analysis:** The framework tests validate actual accepted boundaries, logging the discrepancy.
- **Undocumented Authentication States (403 Forbidden on PUT) - Documented Spec:** The YAML bundles all authentication failures under a single 401 Unauthorized response.
    - **Live API Behaviour:** The live API intelligently differentiates between a missing/malformed token prefix (401 Unauthorized) and a correctly formatted but invalid token string (403 Forbidden) on the PUT endpoint.
    - **Analysis:** The live API exhibits superior, clean REST security design, but the YAML specification is incomplete. The framework asserts the live 401/403 split.
- **Authentication Error Message Mismatch**
    - **Documented Spec:** The YAML states that a 401 response should return the body {"error": "Unauthorized"}.
    - **Live API Behaviour:** The API actually returns {"error": "Authentication required"} when a token is missing.
    - **Analysis:** Minor contract deviation. The framework's assertions were updated to match the live error message.
- **Undocumented Resource States (404 Not Found on PUT)**
    - **Documented Spec:** The YAML fails to define the expected response when attempting to update a non-existent booking ID.
    - **Live API Behaviour:** The API correctly handles this edge case by returning a 404 Not Found with the body {"error": "Failed to update booking"}.
    - **Analysis:** The API handles the logic correctly, but the documentation is missing.

2. Functional API Anomalies

These findings represent unexpected logic handling within the live API that should be reviewed by the backend team.

- **PUT Updates Silently Ignore roomid**
    - **Documented Spec:** A PUT request replaces the entire resource, implying all provided fields (including roomid) should be updated.
    - **Live API Behaviour:** The API returns a {"success": true} response when a new roomid is submitted via PUT. However, secondary verification via GET reveals the roomid remains unchanged.
    - **Analysis:** The backend appears to lock the roomid upon creation. The framework successfully updates other fields but logs a contract deviation for the ignored roomid.

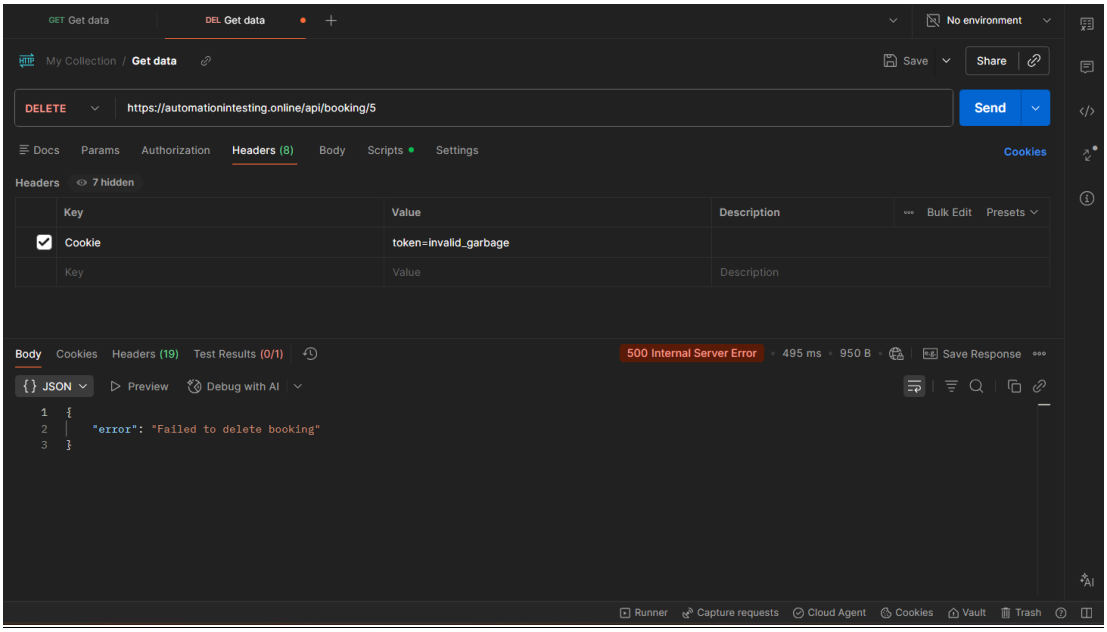
- **Missing Endpoint: PATCH /booking/{id}**
    - **Documented Spec:** The YAML promises a PATCH endpoint for partial updates.
    - **Live API Behaviour:** The endpoint returns a 405 Method Not Allowed.
    - **Analysis:** The endpoint was never implemented in the live environment. An explicit @bug scenario was written to assert this 405 response.



- **Lenient Boolean Coercion**
    - **Live API Behaviour:** When passing an integer 1 for the depositpaid boolean field, the API's JSON parser (Jackson) leniently coerces the binary 1 into true rather than rejecting the schema mismatch with a 400 Bad Request.

3. Critical Stability Issues

- **Authentication Parser Crash (500 Internal Server Error)**
    - **Live API Behaviour:** When an API consumer sends a DELETE request with a malformed token value that still includes the token= prefix (e.g., Cookie: token=invalid_garbage), the server fails to decrypt it. Instead of catching the error and returning a 401 Unauthorized or 403 Forbidden (as the PUT endpoint correctly does), the backend code crashes, throwing a 500 Internal Server Error.
    - **Analysis:** This is a severe unhandled exception in the API's security filter. The framework isolates this specific malformed input into dedicated @bug scenarios to document the crash without causing flaky pipeline failures.


GET Get data
DEL Get data
No environment
My Collection / Get data
Save
Share
DELETE
https://automationintesting.online/api/booking/5
Send
Docs
Params
Authorization
Headers (8)
Body
Scripts
Settings
Cookies
Headers
7 hidden
Key
Value
Description
Bulk Edit
Presets
Cookie
token=invalid_garbage
Key
Value
Description
Body
Cookies
Headers (19)
Test Results (0/1)
500 Internal Server Error
495 ms
950 B
Save Response
JSON
Preview
Debug with AI
{
"error": "Failed to delete booking"
}
Runner
Capture requests
Cloud Agent
Cookies
Vault
Trash